

الوحدة 12: الاستكشاف وجمع المعلومات (Reconnaissance)

Passive Recon (الاستكشاف السلبي)

جمع معلومات عن الهدف دون التفاعل المباشر معه. يصعب كشفه لأنه لا يترك أثراً في سجلات الهدف.

مصادر OSINT: وسائل التواصل الاجتماعي، whois، LinkedIn، Shodan، Google Dorking.

Whois: قاعدة بيانات تحتوي على معلومات عن نطاقات الإنترنت (المالك، تاريخ التسجيل، DNS).

مثال: استخدام whois

```
whois example.com
```

الشرح: يعرض معلومات تسجيل النطاق: المالك، جهة التسجيل، تواريخ الإنشاء وال انتهاء، خوادم DNS. مفيد لجمع معلومات عن الهدف في مرحلة Passive Recon.

مثال: استخدام nslookup

```
nslookup example.com
```

الشرح: يحل اسم النطاق إلى عنوان IP. يستخدم لمعرفة عنوان IP الخاص بالموقع المستهدف. يمكن تحديد نوع السجل (مثل NS، MX، A) باستخدام type=MX-.

مثال: استخدام dig

```
dig example.com ANY
```

الشرح جزءاً جزءاً:

dig أداة متقدمة للاستعلام عن DNS.

example.com اسم النطاق المستهدف.

ANY يطلب جميع أنواع سجلات (A، AAAA، MX، NS، TXT، DNS، إلخ).

dig يعطي معلومات أكثر تفصيلاً من nslookup.

Active Recon (الاستكشاف النشط)

التفاعل المباشر مع الهدف (إرسال حزم، فحص منافذ). يمكن اكتشافه بسهولة وتركه أثراً في السجلات.

Ping Sweep: إرسال طلب Ping إلى نطاق عناوين IP لتحديد الأجهزة النشطة.

Port Scan: فحص المنافذ المفتوحة على جهاز الهدف لتحديد الخدمات الجارية.

أنواع فحص nmap

(-sS SYN Scan): فحص سريع وشبه مخفي. يرسل SYN ولا يكمل الاتصال (Half-open).

(-sT TCP Connect): يكمل اتصال TCP كامل. أسهل للكشف.

(-sV Service Version): يحدد إصدار الخدمات الجارية على المنافذ المفتوحة.

(-O OS Detection): يحاول تحديد نظام التشغيل بناءً على بصمة TCP/IP.

(-sn Ping Sweep): يرسل طلبات ICMP لتحديد الأجهزة النشطة دون فحص منافذ.

مثال: Ping Sweep باستخدام nmap

```
nmap -sn 192.168.1.0/24
```

الشرح: يفحص جميع الأجهزة النشطة في الشبكة 192.168.1.0/24. يرسل طلبات (Ping) ICMP Echo ويظهر الأجهزة التي تستجيب. هذه أول خطوة في Active Recon.

مثال: فحص متقدم باستخدام nmap

```
nmap -sS -sV -O 192.168.1.100
```

الشرح جزءاً جزءاً:

-sS فحص SYN شبه مخفي.

-sV اكتشاف إصدار الخدمات.

-O اكتشاف نظام التشغيل.

الهدف 192.168.1.100

هذا أمر متكامل يعطي صورة كاملة عن الهدف: المنافذ المفتوحة، الخدمات وإصداراتها، ونظام التشغيل.

Rules of Engagement (قواعد الاشتباك)

قواعد تحدد نطاق الاختبار المسموح به في اختبار الاختراق (Penetration Testing). تشمل:

- نطاق الاختبار: أي الأنظمة مسموح اختبارها وأيها ممنوع.
- التوقيت: أوقات محددة للاختبار (مثلاً خارج ساعات العمل).
- طرق الاتصال: كيفية التواصل مع فريق الأمن الداخلي.
- الحدود: ما هي الإجراءات المسموحة والممنوعة (مثلاً لا لهجمات DoS).
- التوثيق: الحصول على إذن كتابي (ROE document) قبل البدء.

(Quick Quiz (MCQ

?Which reconnaissance method does NOT directly interact with the target .1

- a) Active
- b) Passive
- c) Port Scan
- d) Ping Sweep

Answer: b

:The command `whois example.com` retrieves .2

- a) The IP address only
- b) Domain registration information
- c) Network vulnerabilities
- d) Encrypted passwords

Answer: b

?Which nmap flag attempts to detect service versions .3

- a) -sS
- b) -sT
- c) -sV
- d) -O

Answer: c

?Which tool performs DNS zone transfers and record lookups .4

- a) whois
- b) nslookup
- c) dig
- d) arp

Answer: c

?Which document defines the boundaries and rules for penetration testing .5

- a) SOP
- (b) Rules of Engagement (ROE
- c) SLA
- d) MOU

Answer: b